



✧ ระบบ Login/Logout และการจัดการรหัสผ่าน 🌿

Asst.Prof. Monlica Wattana, Ph.D

Department of Computer Science, Khon Kaen University

CP423324 Database and Web Security





Outline



- Authentication
- การรักษาความปลอดภัยในการ Login/Logout
- กระบวนการ Login/Logout
- Session, Cookie และ \$_SESSION
- ตัวอย่างระบบ Login/Logout ด้วย PHP



Authentication Vs Authorization



- Authentication

ตรวจสอบตัวตน ใช้ Username + Password เกิดขึ้นตอน Login ผลลัพธ์คือ “รู้ว่าใครเข้าใช้”
ตัวอย่าง:

Username + Password → ตรวจสอบรหัสผ่าน → สร้าง Session

- Authorization

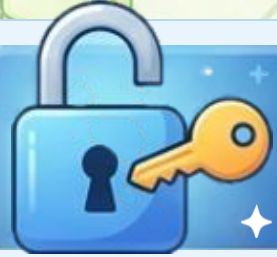
ตรวจสอบสิทธิ์ ใช้ Role / Permission เกิดขึ้นหลัง Login ผลลัพธ์คือ “ทำอะไรได้บ้าง”
ตัวอย่าง:

role = admin / user → กำหนดสิทธิ์การเข้าถึงหน้าหรือเมนูบางส่วน



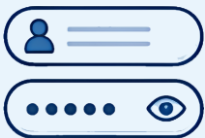
Authentication VS Authorization

ความแตกต่างระหว่างการยืนยันตัวตนและการอนุญาตสิทธิ์



AUTHENTICATION (การยืนยันตัวตน)

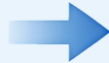
- ตรวจสอบตัวตน: รู้ว่าผู้ใช้เป็นใคร
- ใช้อะไร: Username + Password, MFA (Multi-Factor Authentication)
- เกิดขึ้นเมื่อไหร่: ตอน Login
- ผลลัพธ์: เข้าสู่ระบบได้ และสร้าง Session



กรอก Username
+ Password
(Input Credentials)



2. ระบบตรวจสอบ
ความถูกต้อง
(System Verifies)



สร้าง Session
(Creates Session)

VS



AUTHORIZATION (การอนุญาตสิทธิ์)

- ตรวจสอบสิทธิ์: ทำอะไรได้บ้าง
- ใช้อะไร: Role (บทบาท), Permissions (สิทธิ์การใช้งาน)
- เกิดขึ้นเมื่อไหร่: หลัง Login
- ผลลัพธ์: เข้าถึงทรัพยากรที่ได้รับอนุญาต



ตัวอย่าง: Role = Admin

• จัดการผู้ใช้ • ตั้งค่าระบบ • แก้ไข/ลบข้อมูล



ตัวอย่าง: Role = User

• ดูข้อมูลของตนเอง • สร้างคำขอ
• ไม่เข้าถึงส่วน Admin





การรักษาความปลอดภัยในการ Login/Logout



1. การเก็บ ชื่อผู้ใช้งาน (username) ควรกำหนด UNIQUE เพื่อไม่ให้ซ้ำ
2. การเก็บ รหัสผ่าน (Password)
 - Plain Text Password
 - ถ้าฐานข้อมูลรั่ว ผู้โจมตีเห็นรหัสผ่านทันที
 - username: admin
 - Password: Admin1234
 - Password Hash
 - ฐานข้อมูลเก็บค่าที่ตรวจสอบได้ แต่ไม่ควรถอดกลับเป็นรหัสผ่านเดิม
 - username: student
 - password_hash: \$2y\$10\$...





การรักษาความปลอดภัยในการ Login/Logout



ดังนั้นการเก็บรหัสผ่าน (Password) ควรเก็บข้อมูลผู้ใช้ โดยเก็บรหัสผ่านเป็น

password_hash ไม่ใช่ password จริง

- ไม่ใช่ MD5 หรือ SHA1 สำหรับรหัสผ่าน
- ตอนสร้างบัญชี ควรใช้ password_hash

— Password → **password_hash()** → บันทึก password_hash ในฐานข้อมูล

```
$passwordHash = password_hash(  
    $password,  
    PASSWORD_DEFAULT  
);
```

```
$sql = 'INSERT INTO users  
    (username, password_hash, role)  
    VALUES (?, ?, ?, ?)';
```





การรักษาความปลอดภัยในการ Login/Logout



- ตอน Login ใช้ password_verify()

Password ที่กรอก + password_hash จากฐานข้อมูล

→ password_verify() → true หรือ false

```
if ($user && password_verify($password, $user['password_hash'])) {  
    echo 'Password is correct.';  
}  
else {  
    echo 'Invalid username or password.';  
}
```





การรักษาความปลอดภัยในการ Login/Logout



3. เก็บข้อมูลที่จำเป็น

ควรเก็บเฉพาะข้อมูลที่ระบบจำเป็นต้องใช้ เช่น id, fullname, username, password_hash, role

4. ป้องกันการแสดงผลที่ไม่ปลอดภัย

ข้อมูลจากฐานข้อมูลควรผ่าน htmlspecialchars() ก่อนแสดงใน HTML

```
function h(?string $value): string
{
    return htmlspecialchars(
        $value ?? '',
        ENT_QUOTES | ENT_SUBSTITUTE,
        'UTF-8'
    );
}
```



ตัวอย่าง:

```
<?= h($user['username']) ?>
```





การรักษาความปลอดภัยในการ Login/Logout



5. จำกัดการเข้าถึงข้อมูลตามสิทธิ์

การ Login สำเร็จไม่ได้หมายความว่า ผู้ใช้เข้าถึงข้อมูลทุกอย่างได้ ต้องตรวจสอบ role หรือ Permission ก่อนทำงานสำคัญ เช่น

```
if ($_SESSION['role'] !== 'admin') {  
    http_response_code(403);  
    exit('Access denied.');
```

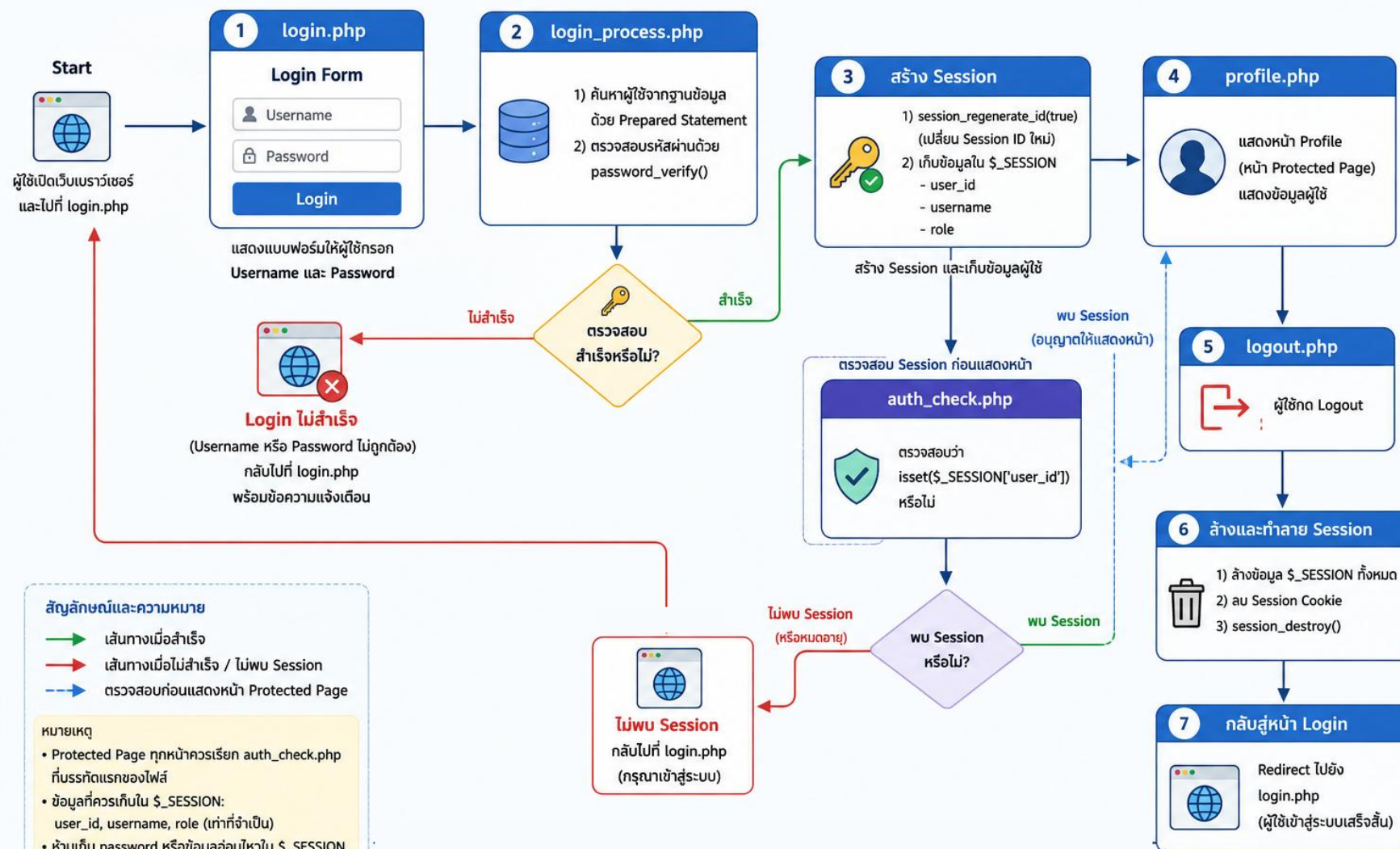
6. ใช้ Prepared Statement ในขั้นตอน Login เพื่อการค้นหาผู้ใช้งาน

```
$stmt = $conn->prepare($sql);  
$stmt->bind_param('s', $username);  
$stmt->execute();
```



กระบวนการ Login/Logout

สรุปกระบวนการ Login / Logout





กระบวนการ Login/Logout



1. **login.php** แสดงแบบฟอร์มรับ Username และ Password
2. **login_process.php** ค้นหาผู้ใช้และตรวจสอบรหัสผ่านด้วย `password_verify()`
เมื่อสำเร็จจะสร้าง Session และไปยังหน้า Profile
3. **auth_check.php** ทำหน้าที่ตรวจสอบ Session ก่อนอนุญาตให้เข้าหน้า
protected page
4. **profile.php** แสดงหน้า protected page ที่เข้าถึงได้เฉพาะผู้ใช้ที่ Login แล้ว
5. **logout.php** ล้างและทำลาย Session แล้วกลับไปยังหน้า Login





การทำงานของ Session ในระบบ Login/Logout



การทำงานของ Session มี 3 อย่างที่ใช้ คือ

1. Session
2. \$_SESSION
3. Cookie





การทำงานของ Session ในระบบ Login/Logout



1. **Session** ข้อมูลฝั่ง Server ที่ใช้จดจำสถานะผู้ใช้ระหว่างเปิดหลายหน้า
 - ใช้จดจำว่าผู้ใช้ Login แล้วหรือยัง
 - เก็บข้อมูลสถานะระหว่างเปิดหลายหน้า
 - สิ่งที่ควร: user_id, fullname, username, role
 - สิ่งที่ไม่ควรเก็บ password, password_hash, ข้อมูลจำนวนมาก หรือข้อมูลลับที่ไม่จำเป็น





การทำงานของ Session ในระบบ Login/Logout



2. \$_SESSION คือตัวแปร PHP ใช้ เขียน-อ่าน ข้อมูลของผู้ใช้

- ต้องเรียก session_start() ก่อนใช้งาน
- เป็น Superglobal Variable ของ PHP

```
session_start();  
// หลัง Login สำเร็จ  
$_SESSION['user_id'] = 1;  
$_SESSION['role'] = 'admin';
```

```
// ตรวจสอบก่อนเข้า profile.php  
if (!isset($_SESSION['user_id'])) {  
    header('Location: login.php');  
    exit;  
}
```





การทำงานของ Session ในระบบ Login/Logout



3. **Cookie** เก็บ Session ID ที่ Browser ส่งให้ Server เพื่อบอกว่า Request นี้เป็นของ Session ไດ

```
Cookie:  
PHPSESSID = abc123xyz
```

Server ใช้ ID นี้ค้นหา Session ของผู้ใช้

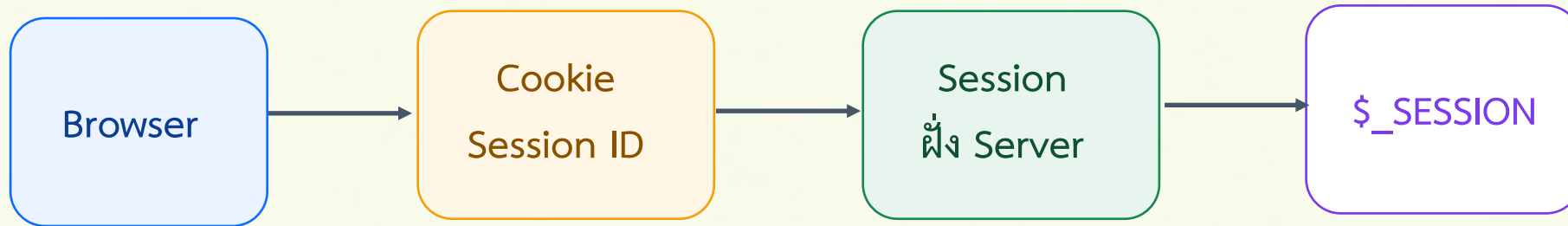




การทำงานของ Session ในระบบ Login/Logout



สรุปการทำงานร่วมกันเพื่อให้ระบบ Login จำสถานะผู้ใช้ได้



เมื่อ Login สำเร็จ → PHP เขียนข้อมูลลง \$_SESSION

เมื่อเปิดหน้า Profile → auth_check.php ตรวจสอบ \$_SESSION['user_id']

เมื่อ Logout → ล้าง \$_SESSION และทำลาย Session





การทำงานของ Session ในระบบ Login/Logout



การทำงานของ Session กับคำสั่ง PHP



```
// profile.php
require_once 'auth_check.php';

// auth_check.php
if (!isset($_SESSION['user_id'])) {
    header('Location: login.php');
    exit;
}
```



การออกจากระบบ(Logout)

ลำดับการ Logout

1. ล้างข้อมูลใน \$_SESSION

```
$_SESSION = [];
```

2. ลบ Session Cookie Browser มักเก็บ Session ID ไว้ใน Cookie ดังนั้นควรทำให้ Cookie หมดอายุด้วย

```
if (ini_get('session.use_cookies')) {  
    $params = session_get_cookie_params();  
    setcookie(  
        session_name(),  
        "",  
        time() - 42000,  
        $params['path'],  
        $params['domain'],  
        $params['secure'],  
        $params['httponly']  
    );  
}
```

การออกจากระบบ(Logout)

ลำดับการ Logout

3. ทำลาย Session ฝั่ง Server

```
session_destroy();
```

4. กลับไปหน้า Login

```
header('Location: Lab06_login.php');  
exit;
```



ตัวอย่างการ Login/Logout

http://localhost:8080/Lec06/create_user.php

Sample users created successfully

admin / Admin1234 / admin

student / Student1234 / user

[Go to Login](#)

phpMyAdmin

id	username	password_hash	role
1	admin	\$2y\$10\$SZgFDih5sq72SL5/8.bvg.sDz3mGOBriRyYgPQzggXy...	admin
2	student	\$2y\$10\$Tthj8FmXiJwxugXZt7Dzh.t5Wlcp/Zoa1v5zlgWVXXU...	user



ตัวอย่างการ Login/Logout (ต่อ)



http://localhost:8080/Lec06/login.php

Login

Username

Password

Login

Login

Username

Password

Login

Profile

User ID: 1

Username: admin

Role: admin

[Logout](#)

เข้าสู่ระบบ (Login)

Login

Username

Password

Login

Profile

User ID: 2

Username: student

Role: user

[Logout](#)





ตัวอย่างการ Login/Logout (ต่อ)



ออกจากระบบ (Logout)

Profile

User ID: 1

Username: admin

Role: admin

[Logout](#)

Login

Username

Password

Login

Username หรือ Password ไม่ถูกต้อง

Login

Username

Password

Login

Login

Invalid username or password.

Username

Password

Login



ตัวอย่างการ Login/Logout (ต่อ)

โครงสร้างฐานข้อมูล

สร้างฐานข้อมูล

```
CREATE DATABASE db_login_demo  
CHARACTER SET utf8mb4  
COLLATE utf8mb4_unicode_ci;
```

สร้างฐานตาราง users

```
CREATE TABLE users (  
  id INT AUTO_INCREMENT PRIMARY KEY,  
  username VARCHAR(50) NOT NULL UNIQUE,  
  password_hash VARCHAR(255) NOT NULL,  
  role VARCHAR(20) NOT NULL DEFAULT 'user'  
);
```



ตัวอย่างการ Login/Logout (ต่อ)

โครงสร้างไฟล์ของระบบ Login/Logout

- config.php: DB + session_start() + h()
- create_user.php: สร้างผู้ใช้ + password_hash()
- login.php: แบบฟอร์ม Username/Password
- login_process.php: SELECT + password_verify() + Session
- auth_check.php: ตรวจสอบสถานะ Login
- profile.php: หน้าสำหรับผู้ที่ Login แล้ว
- logout.php: ล้างและทำลาย Session

Lec06/

- config.php
- create_user.php
- login.php
- login_process.php
- auth_check.php
- profile.php
- logout.php



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ config.php

```
<?php
declare(strict_types=1);
session_start();
// ปรับค่าต่อไปนี้ให้ตรงกับ Docker/XAMPP ที่สร้างไว้
const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_login_demo';
const DB_USER = 'root';
const DB_PASS = 'root';

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);
```



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ config.php (ต่อ)

```
try {  
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);  
    $conn->set_charset('utf8mb4');  
} catch (mysqli_sql_exception $e) {  
    http_response_code(500);  
    exit('Database connection failed.');
```

```
}
```

```
function h(?string $value): string
```

```
{
```

```
return htmlspecialchars($value ?? '', ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
```

```
}
```

ตัวอย่างการ Login/Logout

create_user.php

```
<?php  
declare(strict_types=1);
```

```
require_once 'config.php';
```

```
$users = [  
    ['admin', 'Admin1234', 'admin'],  
    ['student', 'Student1234', 'user']  
];
```

```
$sql = 'INSERT INTO users (username, password_hash, role)  
VALUES (?, ?, ?)  
ON DUPLICATE KEY UPDATE  
password_hash = VALUES(password_hash),  
role = VALUES(role)';
```

```
$stmt = $conn->prepare($sql);
```

id	username	password_hash	role
1	admin	\$2y\$10\$SZgFDih5sq72SL5/8.bvg.sDz3mGOBriRyYgPQzggXy...	admin
2	student	\$2y\$10\$Tthj8FmXiJwxugXZt7Dzh.t5Wlcp/Zoa1v5zlgWVXXU...	user



ตัวอย่างการ Login/Logout (ต่อ)

create_user.php(ต่อ)

```
foreach ($users as [$username, $password, $role]) {  
    $passwordHash = password_hash($password, PASSWORD_DEFAULT);  
    $stmt->bind_param('sss', $username, $passwordHash, $role);  
    $stmt->execute();  
}  
$stmt->close();  
$conn->close();  
?>  
<!doctype html>  
<html lang="en">  
<head><meta charset="utf-8"><title>Create Users</title></head>  
<body>  
    <h1>Sample users created successfully</h1>  
    <p>admin / Admin1234 / admin</p>  
    <p>student / Student1234 / user</p>  
    <p><a href="login.php">Go to Login</a></p>  
</body> </html>
```

Sample users created successfully

admin / Admin1234 / admin

student / Student1234 / user

[Go to Login](#)

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login.php

```
<?php
declare(strict_types=1);

require_once 'config.php';

if (isset($_SESSION['user_id'])) {
    header('Location: profile.php');
    exit;
}

$error = $_GET['error'] ?? "";
?>
<!doctype html>
<html lang="en">
<head><meta charset="utf-8"><title>Login</title></head>
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login.php (ต่อ)

```
<body>
  <h1>Login</h1>
  <?php if ($error === 'required'): ?>
    <p>Username and password are required.</p>
  <?php elseif ($error === 'invalid'): ?>
    <p>Invalid username or password.</p>
  <?php endif; ?>
  <form action="login_process.php" method="post">
    <label>Username</label>
    <input name="username" type="text" required>
    <br> <br>
    <label>Password</label>
    <input name="password" type="password" required>
    <br> <br>
    <button type="submit">Login</button>
  </form>
</body> </html>
```

Login

Username

Password

Login

Login

Invalid username or password.

Username

Password

Login



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login_process.php

```
<?php
declare(strict_types=1);

require_once 'config.php';

if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: login.php');
    exit;
}
$username = trim($_POST['username'] ?? '');
$password = $_POST['password'] ?? '';

if ($username === '' || $password === '') {
    header('Location: login.php?error=required');
    exit;
}
```

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login_process.php (ต่อ)

```
$sql = 'SELECT id, username, password_hash, role
      FROM users WHERE username = ?';
$stmt = $conn->prepare($sql);
$stmt->bind_param('s', $username);
$stmt->execute();

$user = $stmt->get_result()->fetch_assoc();
if ($user && password_verify($password, $user['password_hash'])) {
    session_regenerate_id(true);
    $_SESSION['user_id'] = (int) $user['id'];
    $_SESSION['username'] = $user['username'];
    $_SESSION['role'] = $user['role'];
    header('Location: profile.php');
    exit;
}
header('Location: login.php?error=invalid');
exit;
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ auth_check.php

```
<?php
declare(strict_types=1);

require_once 'config.php';

if (!isset($_SESSION['user_id'])) {
    header('Location: login.php');
    exit;
}
```



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ profile.php

```
<?php
declare(strict_types=1);
require_once 'auth_check.php';
?>

<!doctype html>
<html lang="en">
<head><meta charset="utf-8"><title>Profile</title></head>
<body>
  <h1>Profile</h1>
  <p>User ID: <?= h((string) $_SESSION['user_id']) ?></p>
  <p>Username: <?= h($_SESSION['username']) ?></p>
  <p>Role: <?= h($_SESSION['role']) ?></p>
  <p><a href="logout.php">Logout</a></p>
</body>
</html>
```

Profile

User ID: 1

Username: admin

Role: admin

[Logout](#)

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ logout.php

```
<?php
declare(strict_types=1);
require_once 'config.php';
$_SESSION = [];

if (ini_get('session.use_cookies')) {
    $params = session_get_cookie_params();
    setcookie(
        session_name(),
        "",
        time() - 42000,
        $params['path'],
        $params['domain'],
        $params['secure'],
        $params['httponly']
    );
}
```

```
session_destroy();
```

```
header('Location: login.php');
exit;
```

กรณีทดสอบการ Login/Logout

1. Login ด้วยข้อมูลถูกต้อง ต้องสามารถเข้าหน้า Profile แสดงข้อมูลที่ถูกต้อง

Login

Username

admin

Password

.....

Login

Profile

User ID: 1

Username: admin

Role: admin

[Logout](#)

2. Login ด้วย Password ผิด ต้องแสดงข้อความ Invalid username or password.

Login

Username

admin

Password

.....

Login

Login

Invalid username or password.

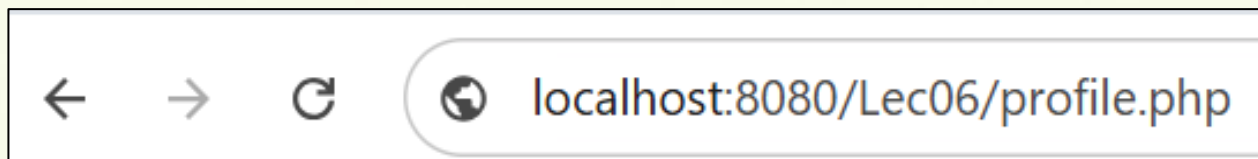
Username

Password

Login

กรณีทดสอบการ Login/Logout (ต่อ)

3. ถ้าใส่ URL ไปยังหน้า profile.php โดยยังไม่ Login ต้องกลับไปหน้า Login



← → ↻ 🌐 localhost:8080/Lec06/profile.php

Login

Username

Password

Login

4. ทดลอง SQL Injection: ' OR '1'='1 ต้องแสดงข้อความ Invalid username or password.

Login

Username ' OR '1'='1

Password

Login

Login

Invalid username or password.

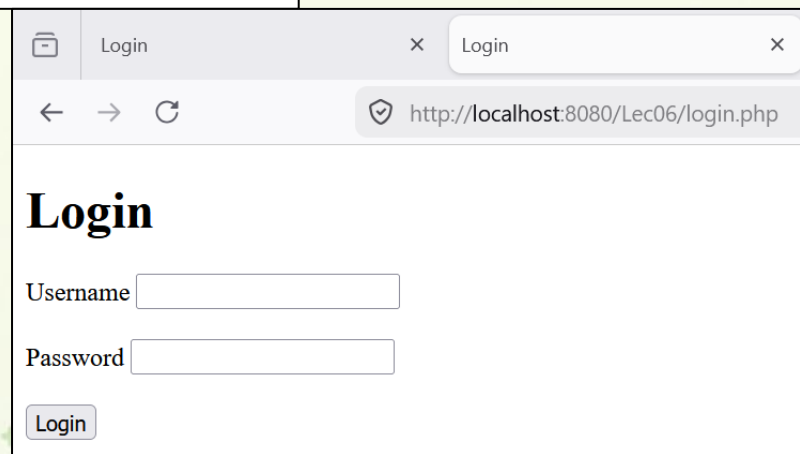
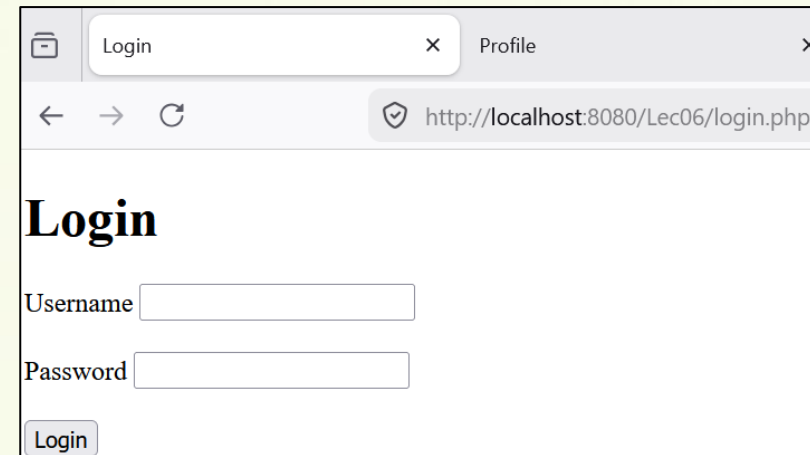
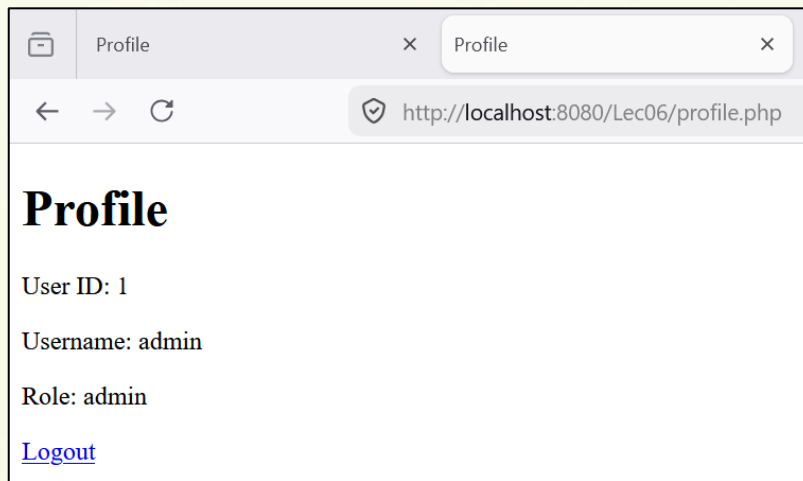
Username

Password

Login

กรณีทดสอบการ Login/Logout (ต่อ)

5. เปิด Profile 2 Tab จากนั้น Logout อันที่ 1 แล้ว Refresh อีก Tab ต้องกลับไปหน้า Login





อ้างอิง



- PHP Documentation. Password Hashing Functions.
- PHP Documentation. Session Handling Functions.
- PHP Documentation. MySQLi Prepared Statements.
- OWASP Foundation. Password Storage Cheat Sheet.
- OWASP Foundation. Session Management Cheat Sheet.
- OWASP Foundation. SQL Injection Prevention Cheat Sheet.
- Oracle. MySQL Reference Manual: Prepared Statements.

